CASE-002 Incident Report

Credential Phishing and Suspected Account Compromise

Case ID	CASE-002	**Severity**	High
Lab ID	PHISH-2026-A	**Status**	Investigation complete - synthetic lab
Primary vector	Credential-phishing link	**Gateway action**	Delivered
Key source IP	203.0.113.200	**Correlation gap**	250 seconds

Executive Summary

CASE-002 is a synthetic Microsoft 365 credential-phishing scenario in which a delivered email used a brand-lookalike sender domain and a login-themed URL. The user clicked the phishing link at **10:06:30 UTC**. A suspicious successful sign-in occurred at **10:10:40 UTC**, only **250 seconds** later, from **203.0.113.200**. The sign-in condition used by the lab showed MFA as not satisfied.

The sequence is consistent with credential phishing followed by suspected use of captured credentials. Temporal proximity alone does not prove that credentials were stolen; however, the combination of the phishing lure, user interaction, suspicious authentication, and identity context supports a High severity investigation and immediate account containment.

Incident Scope

Component	Observed evidence
Email identity	Display name: Microsoft 365 Security; sender: security-alert@micr0soft-security.example
Subject	Unusual Microsoft 365 sign-in - verify now
Phishing URL	https://login-security-m365.example/session/validate
Email authentication	SPF: pass; DKIM: pass; DMARC: pass
Delivery	Gateway action: delivered
User activity	Phishing link clicked
Identity activity	Successful sign-in with MFA not satisfied

Timeline of Events

Time (UTC)	Event	Analyst interpretation
2026-09-20 10:06:30	User clicked phishing link	Confirmed interaction with credential-phishing lure.
2026-09-20 10:10:40	Suspicious successful sign-in	Successful authentication from 203.0.113.200 with MFA not satisfied.
+250 seconds	Correlation interval	Sign-in occurred 4 minutes 10 seconds after link click.

Evidence Analysis

1. Brand-lookalike sender

The sender address uses **micr0soft-security.example**, replacing the letter "o" in Microsoft with the digit "0". This is consistent with a lookalike-domain social-engineering technique intended to create visual trust.

2. Security-verification lure

The subject claims an unusual Microsoft 365 sign-in and urges the recipient to verify immediately. This security-themed pretext is designed to drive the recipient toward the embedded login URL.

3. Login-themed URL

The URL **login-security-m365.example/session/validate** resembles a Microsoft 365 security workflow but does not use a Microsoft-owned domain in the synthetic scenario.

4. Authentication controls passed

SPF, DKIM, and DMARC all passed for the message. This illustrates an important SOC principle: successful domain authentication does not guarantee that the message itself is benign. An attacker-controlled domain can authenticate its own malicious mail correctly.

5. Post-click sign-in correlation

The suspicious successful sign-in occurred 250 seconds after the link click. In the lab telemetry, the sign-in condition also showed MFA as not satisfied. This sequence materially increases the likelihood of account impact and warrants immediate identity containment.

Indicators of Interest

Indicator	Type	Context
security-alert@micr0soft-security.example	Email sender	Brand-lookalike sender
micr0soft-security.example	Domain	Lookalike sender domain
login-security-m365.example	Domain	Credential-phishing URL domain
https://login-security-m365.example/session/validate	URL	Phishing link clicked by user
203.0.113.200	IP address	Suspicious successful sign-in source (documentation IP)

Detection and Correlation Logic

The correlation query creates temporary timestamp fields only when an event matches the relevant condition. **click_epoch** is populated for a **user_action** whose action is **clicked_link**. **signin_epoch** and **suspicious_ip** are populated for a successful **identity_signin** where MFA is not satisfied. **stats min(...)** then selects the earliest click and suspicious sign-in for the case, allowing Splunk to calculate the interval.

```
index=phishing_lab earliest=0
| spath
| search lab_id="PHISH-2026-A" case_id="CASE-002"
| dedup event_id
| eval _time=strptime(timestamp,"%Y-%m-%dT%H:%M:%SZ")
| eval click_epoch=if(event_type="user_action" AND action="clicked_link",_time,null())
| eval signin_epoch=if(event_type="identity_signin" AND result="success" AND mfa="not_satisfied",_time,null())
| eval suspicious_ip=if(event_type="identity_signin" AND result="success" AND
mfa="not_satisfied",source_ip,null())
| stats min(click_epoch) as click_epoch min(signin_epoch) as signin_epoch values(suspicious_ip) as suspicious_ip
by case_id
| eval seconds_after_click=signin_epoch-click_epoch
```

MITRE ATT&CK; Mapping

Technique	Relevance
T1566.002 - Phishing: Spearphishing Link	The user received and clicked a credential-phishing link.
T1078 - Valid Accounts	Relevant if the successful post-click sign-in used credentials captured through the phishing flow.

Risk Assessment

Factor	Assessment
Delivery	Email reached the user.
Interaction	User clicked the phishing link.
Identity impact	Suspicious successful sign-in followed within 250 seconds.
MFA state	Synthetic sign-in event showed MFA not satisfied.
Confidence	High confidence that the email is credential phishing; suspected account compromise requires containment and validation.

Containment and Remediation Recommendations

1. Revoke active sessions

Terminate existing authentication sessions for the affected identity.

2. Reset credentials

Force a password reset through a trusted administrative workflow.

3. Validate MFA

Review MFA methods, re-register as required, and verify that no unauthorized method was added.

4. Review identity activity

Investigate sign-ins before and after the suspicious event, including source IP, device, application, conditional access, geography, and risk.

5. Block phishing infrastructure

Block or monitor the sender/URL domains according to security policy.

6. Hunt across users

Search for the same sender, subject, URL, and source IP across all recipients and identities.

7. Check persistence

Review mailbox forwarding, inbox rules, OAuth grants, and other persistence mechanisms if account access is confirmed.

8. Preserve evidence

Retain email, Splunk telemetry, identity logs, and response actions for incident documentation.

Conclusion

CASE-002 demonstrates a realistic SOC workflow in which an apparently authenticated email is still malicious because the sender identity and URL are deceptive. The key analytical step is correlation: a confirmed phishing-link click is followed 250 seconds later by suspicious successful identity activity. The appropriate SOC response is to treat the message as credential phishing, prioritize identity containment, validate the extent of account impact, and hunt for related activity.

This report is based on synthetic training data and is intended for portfolio and learning use only.